STANDAR KEAMANAN WEBSITE
Anti Serangan Hacker

Dokumen ini berisi panduan standar keamanan website berbasis PHP/HTML/JavaScript untuk mencegah serangan hacker.

1. Prinsip Dasar Keamanan

- Validasi semua input pengguna
- Gunakan prinsip least privilege
- Enkripsi data sensitif
- Update sistem secara berkala
- Monitoring dan logging aktif

2. Keamanan Input & SQL Injection

- Gunakan Prepared Statement (PDO/MySQLi)
- Jangan menyisipkan input user langsung ke query
- Gunakan filter_input dan htmlspecialchars

3. Proteksi XSS

- Escape semua output ke browser
- Gunakan Content-Security-Policy
- Hindari echo data mentah dari user

4. Proteksi CSRF

- Gunakan token CSRF di setiap form penting
- Validasi token saat submit
- Wajib untuk login, update, delete

5. Keamanan Login & Password

- Gunakan password_hash dan password_verify
- Batasi percobaan login
- Gunakan CAPTCHA jika perlu

6. Manajemen Session

- Gunakan cookie_httponly dan secure
- Regenerate session ID setelah login
- Hindari session di URL

7. Keamanan Upload File

- Validasi MIME type file
- Batasi jenis file
- Simpan file di luar public folder

8. Hak Akses & Role

- Pisahkan role admin, operator, user
- Validasi akses di setiap halaman sensitif

9. Struktur Folder Aman

- Pisahkan public dan core aplikasi
- Lindungi file config dan environment

10. Konfigurasi Server

- Matikan display error di production
- Gunakan HTTPS/SSL
- Gunakan .htaccess untuk proteksi

11. Logging & Monitoring

- Catat aktivitas login dan error
- Simpan IP, waktu, dan aksi
- Audit log secara rutin

12. Proteksi Tambahan

- Gunakan WAF / Cloudflare
- Backup rutin
- Scan keamanan berkala

Penutup

Dengan menerapkan standar ini, website akan jauh lebih aman dari serangan umum seperti SQL Injection, XSS, CSRF, dan malware upload.